



From Inbox to Intrusion: Unmasking a Phishing Campaign Delivering Agent Tesla

Analyst - Idus E.

Executive Summary

On 16 September 2025, an investigation was conducted on a simulated phishing email received in a controlled corporate lab environment. The analysis confirmed with high confidence that the email was a malicious attempt to deploy Agent Tesla, a credential-stealing malware.

The attacker spoofed a legitimate sender and used social engineering, urging the recipient to open an attachment disguised as a *"Statement of Account."*

Key Evidence

- **Failed SPF authentication** → forged sender domain
- **Attachment verdict:** 50/67 detections on VirusTotal → *Agent Tesla*

Potential Impact: Financial fraud, large-scale data breaches, ransomware deployment, and reputational harm.

Recommendations:

- Block identified indicators and quarantine malicious files.
- Issue a company-wide security advisory.
- Long-term: enforce **DMARC**, deploy **attachment sandboxing**, and expand **EDR coverage**.

Phase 1 — Introduction

This report analyzes a simulated phishing email delivered on 22 September 2023. Objective: Deconstruct its components, identify red flags, and strengthen organizational awareness and defense protocols.



Phase 2 — Analysis of Metadata (Parsing & Artifact Extraction Methodology)

The suspicious email was exported in **.eml format**, which preserves the full raw source including headers, body content, and attachments. To safely convert this raw data into a structured format for examination, the **eml_parser** utility and a custom Python script were used. Parsing ensures each component can be reviewed systematically without rendering active content such as HTML or embedded scripts — reducing the risk of accidental execution.

Controlled Environment

All work was conducted inside a dedicated **virtual machine (VM)** to contain potential threats and allow easy rollback to clean snapshots.

- **Virtualization Platform:** VMware Workstation
- **Operating System:** Kali Linux

This environment provides a hardened sandbox preloaded with forensic and analysis tools.

Workflow

01	02	03
Email Acquisition	Parsing & Extraction	Outputs
• Exported .eml sample from MailHog/GoPhish • Transferred file into the VM for examination	• Headers: From, Subject, Date, Message-ID, Return-Path • Body: Plain text and HTML components • URLs: Extracted embedded links for reputation analysis • Attachments: Saved locally, hashed (MD5, SHA1, SHA256)	• summary.csv — overview of parsed email metadata • JSON reports — per-message structured output • Saved artifacts — attachments with cryptographic hashes

Key Benefit: This standardized workflow produced repeatable results, enabling faster triage, reliable identification of indicators of compromise (IOCs), and streamlined sharing with threat intelligence platforms.

Phase 3 — Analysis Findings

The parsed data was subjected to deeper review across headers, content, and attachments. Findings confirm with **high confidence** that this email represents a **malicious phishing attempt** intended to deliver a credential-stealing Trojan.

Header Analysis — Spoofing Indicators

Authentication Failure

Authentication-Results header reported spf=fail. This means the sending IP (193.42.33.171) was not authorized to send mail on behalf of coretek.cn, indicating spoofed sender identity.

Suspicious Origin IP

Received headers confirmed origination from 193.42.33.171, geolocating to a region inconsistent with the supposed sender. This strengthens the conclusion of spoofing.

Content Analysis — Social Engineering Tactics

- **Deceptive Subject Line:** *"RE: SOA as at 20th September 2023"* leverages the "RE:" prefix to mimic an ongoing thread and lower suspicion.
- **Urgency & Finance Context:** References to a *"Statement of Account"* requesting balance confirmation and remittance status represent classic **Business Email Compromise (BEC)** techniques.
- **Generic Language:** The lack of personalized details and use of broad salutations further indicate a fraudulent attempt to impersonate legitimate business communication.

Attachment Analysis — Malware Payload Confirmation

- **Attachment:** STATEMENT OF **ACCOUNT.zip**
- **SHA-256:**
e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8
- **VirusTotal Results:** 50/67 vendors flagged the file as malicious.
- **Identified Malware:** Multiple engines classified the payload as **Agent Tesla**, a notorious information stealer.

Capabilities:

- Keylogging & clipboard theft
- Credential harvesting (email, browsers, VPN, FTP)
- Screenshot capture & system profiling
- Exfiltration via HTTP/HTTPS, SMTP, FTP, Telegram

Extracted Executable:

- STATEMENT OF ACCOUNT.exe
- **SHA-256:** 7a7c13b3a488e5198ef87d64a8e7cb54a8bb5eadef1cbfb7a76888a8b7a6353b
- Also detected as **Agent Tesla / MSIL.Krypt**.

Infrastructure & Command-and-Control (C2)

Analysis revealed associated malicious infrastructure:

Active IPs:

- 104[.]237[.]62[.]212
- 162[.]241[.]169[.]155
- 93[.]184[.]221[.]240
- 173[.]254[.]28[.]237 → resolves to mail.expertsconsultgh.co
- **Auxiliary Services:** Abuse of legitimate APIs such as api.ipify.org for victim IP fingerprinting.
- **Inference:** Rotating C2 infrastructure indicates a sustained, organized campaign.

Risk & Impact Assessment

Threat Level: 🚨 **High**

Business Risks:

- Credential theft enabling fraud and unauthorized access
- Potential data breach or exfiltration of sensitive IP
- Lateral movement leading to ransomware deployment
- Reputational damage and regulatory penalties

Recommendations

Immediate Actions

- Quarantine malicious ZIP/EXE artifacts
- Block related IPs/domains on firewall, DNS, and EDR
- Isolate affected endpoints and reset compromised credentials

Strategic (30-60 Days)

- Enforce DMARC with reject/quarantine policy
- Deploy sandboxing and restrict ZIPs containing executables
- Enhance DNS filtering and TLS inspection
- Expand EDR coverage with behavioral detections
- Deliver targeted phishing-awareness training
- Update SIEM rules to detect infostealer activity

MITRE ATT&CK Mapping

	T1566.001 Phishing: Attachment
	T1204 User Execution
	T1555.003 / T1056.001 Credential Access
	T1082 System Information Discovery
	T1041 Exfiltration Over C2 Channel
	T1071 Application Layer Protocol

Conclusion

The convergence of failed SPF validation, anomalous IP origin, deceptive social engineering tactics, and confirmed malware detection establishes this email as a malicious phishing campaign. Its objective was to trick recipients into opening a disguised attachment, triggering installation of the Agent Tesla Trojan, thereby compromising credentials and enabling further system exploitation.

This campaign highlights the persistent threat of phishing paired with commodity malware like *Agent Tesla*. Through analysis of spoofed headers, malicious payloads, and active C2 infrastructure, the malicious nature of the email was confirmed. Organizations should treat such incidents as priority-level threats, combining immediate blocking and host isolation with long-term hardening of email and endpoint security defenses.